

BSides Birmingham 2026

From Payloads to People: The Other Half of the Job

Dumisani Masimini





Let's Check In

Quick show of hands...

- 🖐 Who here has written a pentest report?
- 🖐 Who has sat on a client debrief call?
- 🖐 Who has had a client not act on findings?
- 🖐 Who has ever struggled to explain a vulnerability in plain English?

You're not alone. This is the talk I needed when I was starting out.

What We're Covering Today

- 01 Who I am — and why this matters
- 02 The payloads side: what we do technically
- 03 The people side: reports, debriefs, relationships
- 04 Translating tech into business language
- 05 Running effective debriefs
- 06 Soft skills that set you apart
- 07 Real lessons — the hard way
- 08 Practical takeaways you can use today





Who Am I?

6+

years in pentesting

3

BSides talks

100+

client engagements

Penetration Tester @ ~~Pentest People~~ Worknest Secure

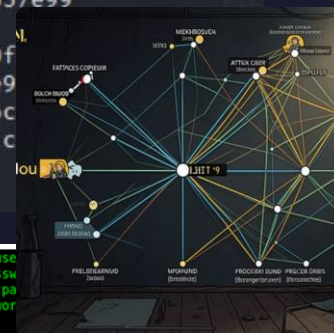
“The best pentest in the world is worthless if nobody acts on the findings.”

```

[*] Servers started, waiting for connections
[*] SMBD-Thread-4: Connection from BRAVOTEAM/SPENSER@10.10.10.69
[*] Authenticating against smb://10.10.10.55 as BRAVOTEAM/SPENSER SUCCEEDED
[*] SMBD-Thread-4: Connection from BRAVOTEAM/SPENSER@10.10.10.69 controlled
-] Authenticating against smb://10.10.10.69 as BRAVOTEAM/SPENSER FAILED
[*] Service RemoteRegistry is in stopped state
[*] Starting service RemoteRegistry
[*] Target system bootKey: 0x1acf7339e7d4eca55681fa9795657e99
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:59fc0f
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae9
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6c
DAGUtilityAccount:504:aad3b435b51404eeaad3b435b51404ee:c
[*] Done dumping SAM hashes for host: 10.10.10.55
[*] Stopping service RemoteRegistry

```

```
R@10.10.10.69 co
```



```
vwa'
abase 'dvwa'
ry-based att
```

```
Database: dvwa
Table: users
[5 entries]
```

```
[11:34:02] [INFO] table 'dwa.users' dumped to CSV file '/pentest/database/sqlmap/output/192.168.152.129/dump/
dwa/users.csv'
[11:34:02] [INFO] fetched data logged to text files under '/pentest/database/sqlmap/output/192.168.152.129'
```

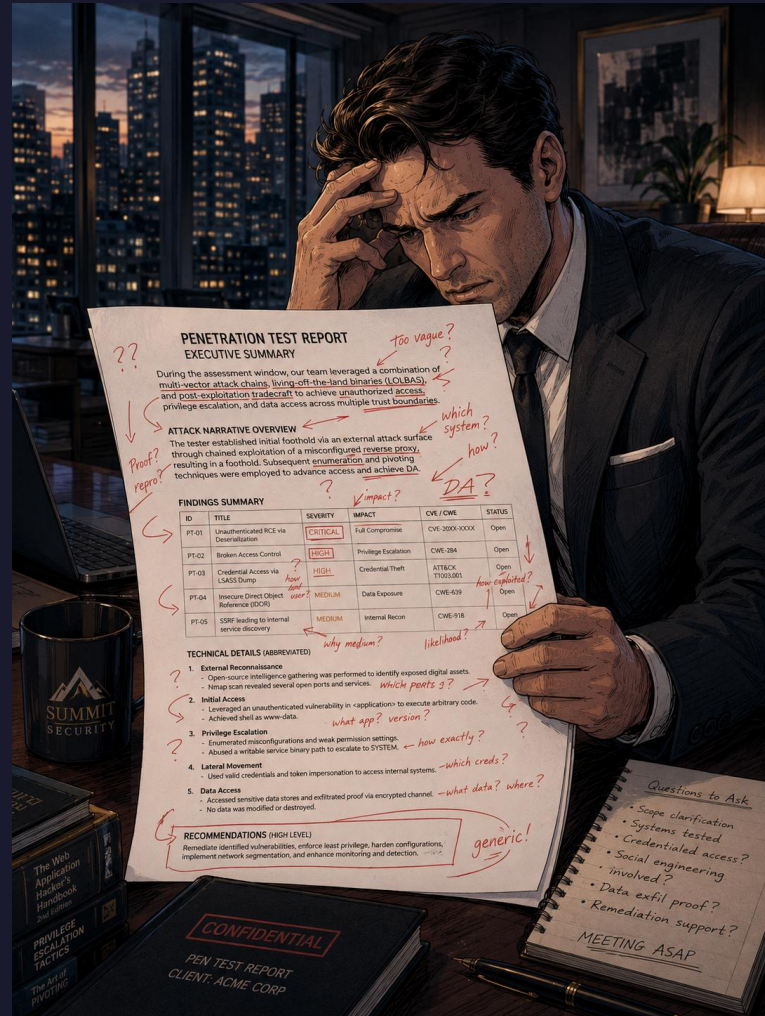
The Payloads Side: What people think we do



The Payloads Side: What we do when no one is watching



The Payloads Side: What we do when no one is watching



An illustration of a man with dark skin and short black hair, wearing a dark blue suit, white shirt, and blue tie. He is looking slightly to the right with a calm expression. The background behind him is a warm, orange-toned office interior with large windows and desks.

The Gap Pentesters Don't See Coming

What You're Trained For

- Shell access and exploitation
- Burp Suite, payloads, CVEs
- Enumeration and privilege escalation
- Technical depth and tooling

What the Job Actually Requires

- Reports that drive action
- Debrief calls that build trust
- Communication that creates change
- Translating risk into business impact

Bridge the Gap



A stylized illustration of a man with dark skin, short black hair, and a friendly expression. He is wearing a dark blue suit jacket over a white shirt and a dark tie. The background behind him is a warm, orange-toned office interior with large windows and desks.

What Clients Actually Want to Know

Clients aren't thinking about CVSS scores. They're thinking about their **business.**

“How bad is this, really?”

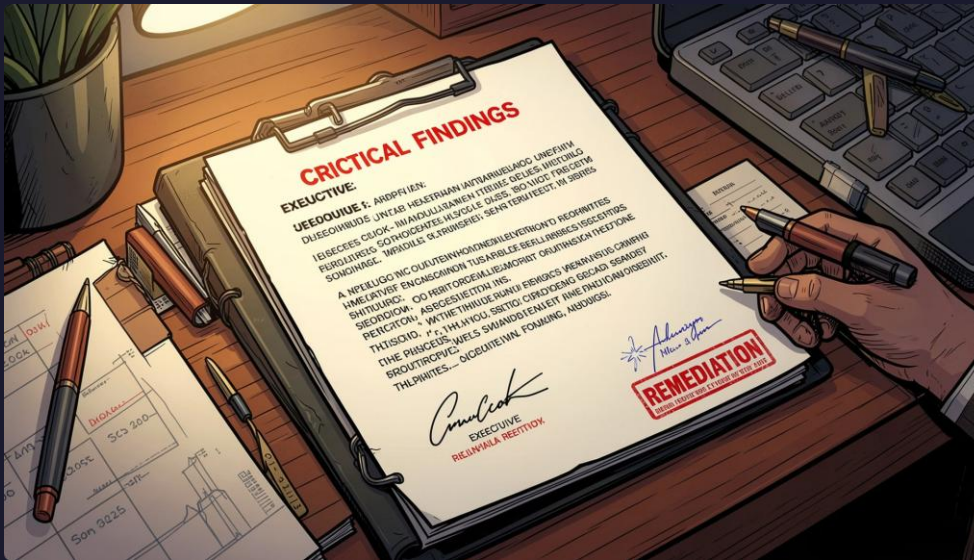
“Are we exposed right now?”

“How does this affect our customers?”

“What do we fix first?”

These are the questions you must be prepared to answer — in plain, confident language — before you open the report.

The Deliverable that lasts: the Report



Evidence for Auditors

Documented findings, timestamps, and methodology — the paper trail that satisfies compliance.

Guidance for Engineers

Clear remediation steps that turn a vulnerability into a ticket, and a ticket into a fix.

Risk Context for Leadership

Business impact, likelihood, and urgency — translated into the language of decisions.

The Lasting Memory of Your Engagement

Not the shell. Not the exploit. The document they reference six months later.

Report Writing: The Document Everyone Reads

✗ BEFORE (the bad version)

Title: CVE-2021-44228 — Apache Log4j RCE

CVSS Score: 10.0 (Critical)

Description: An unauthenticated remote code execution vulnerability exists in Apache Log4j2 versions 2.0-beta9 through 2.14.1 via the `{jndi}` lookup feature. A remote attacker can exploit this to execute arbitrary code via a specially crafted string.

Remediation: Upgrade to Apache Log4j 2.16.0 or later. Apply vendor patch. Review JNDI configuration.

✓ AFTER (the good version)

An attacker with no credentials can take complete control of your servers remotely.

What this means for you: Anyone on the internet could access, steal, or destroy your customer data and internal systems — with no warning and no trace.

We found this on your public-facing logging system. It is actively exploited in the wild right now.

What to do: Your IT team needs to apply a single update (Log4j 2.15.0) this week. We can walk them through it. This is your highest priority fix.

Auditors, executives, and engineers all open the same file. It has to speak to all three.

Report Writing: Before vs After

How to talk to non-technical stakeholders.

- 1 Lead with impact, not technical detail
- 2 Use analogies
- 3 Show what an attacker gains
- 4 Tie findings to business processes
- 5 Keep CVSS in the appendix

Remember: clients don't need to understand the exploit. They need to understand the consequence.

A stylized illustration of a man with dark skin, short black hair, and a friendly expression. He is wearing a dark blue suit jacket over a white shirt and a dark tie. The background behind him is a warm, orange-toned office interior with large windows and desks.

How to Speak Client

Same finding. Two different languages.

✗ Jargon version:

“We identified an unauthenticated SQL injection vulnerability with a CVSS score of 9.8 in the login endpoint, enabling full database compromise.”

✓ Plain English version:

“We found a way to access your entire customer database without a password — using just a web browser. Anyone who found this could read, steal or delete every record you hold.”

The second version gets fixed. The first gets filed away.

An illustration of a man with dark skin and short black hair, wearing a dark blue suit, white shirt, and dark tie. He is smiling slightly and looking towards the right. The background behind him is a warm, orange-toned office interior with large windows and desks.

Running Effective Debriefs

01

Start with Impact

Lead with what matters most to the client.

02

Explain Attacker Path

Show how an attacker moves through the system.

system.
03

Prioritize Fixes

Give clear, actionable next steps.

04

Invite Questions

Create space for the room to engage.

05

End with Reassurance

Leave them confident, not afraid.

What Great Consultants do: Soft Skills That Set You Apart



Explain Clearly



Stay Calm



Build Confidence



Make People Feel Supported



Adapt to the Room

An illustration of a man with dark skin and short black hair, wearing a dark blue suit, white shirt, and blue tie. He is looking slightly to the right with a subtle smile. The background behind him is a warm, orange-toned office interior with large windows and desks.

Mistakes That Kill Your Impact

01 Jargon overload

CVEs and CVSS scores mean nothing to a CFO.

02 No executive summary

Decision makers stop reading after page 1.

03 Findings not prioritised

If everything is critical, nothing is critical.

04 Reading the report aloud

A debrief is a story, not a recital.

05 Getting defensive

A challenged finding is a conversation, not an attack.

05 Forgetting the Human

Behind every vulnerability is a person who has to fix it.

What I've Learned (the Hard Way)

- Stories from real engagements.
- What worked — and what didn't.
- Growth moments as a consultant.

WHAT I'VE LEARNED (the HARD WAY

BREAKING THE NETWORK

Ran nmap without permission...



KEEPING CALM

Acknowledge the mistake.
Stay calm.



GROWTH MOMENTS

It's about finding solutions, not blame.



Practical Takeaways

Five things you can apply starting with your next engagement – whether you're writing your first report or your hundredth.

1

Lead with Business Impact

Clients remember risk in dollars and reputation – not CVE IDs.

2

Write for All Audiences

Executive summary up top, technical depth below. Serve both readers in a single document.

3

Lead Conversations

Don't just present findings. Drive the discussion.

4

Build Soft Skills Deliberately

Train communication with the same discipline you bring to a CTF.

5

Thank You



Dumisani Masimini
Penetration Tester



Questions, connections, and conversations welcome.

Q&A